AI TRUST FRAMEWORK
For the regulator, the auditor, the room
04 May 2026 · v1.0

Why we trust the AI

— and why a SAHPRA inspector should too.

The honest answer: **AI can hallucinate, so we built the system assuming it does.** Every layer assumes the AI might be wrong, and every regulated artefact passes a 3-person sign-off chain before it counts. The AI accelerates the work; the named humans on the licence stay accountable.

01 How we tell fake from real

Every AI output is visibly marked, separately stored, and signature-gated.

ASKED	WHAT THE SYSTEM SHOWS YOU	WHERE IT LIVES
Is this section the real SMF yet?	A green `AR_APPROVED` badge plus RP/DAR/AR signatures dated. Anything else is provisional. AR-approved sections are frozen as a `SMFSectionVersion` snapshot.	Status badge on every section
Is this AI-generated?	A bold red **"AI-GENERATED · NOT YET APPROVED"** banner with red border. Lives in a separate `composedDraft` field — never in the canonical `bodyText` until a human clicks Apply (which resets the entire 3-stage sign-off chain).	SMF section modal · only when draft exists
Is this number the AI made up?	Below every chat reply, a **"Grounded in live data"** footer lists the exact DB facts that fed the answer (e.g. *50 plants · 2 active batches · 1 open ticket · 56 SMF drafts · 2 approved sections*).	Floating chat panel (every dashboard)
Was this ticket created by the system?	Tickets carry a `ticketType` tag — `SMF_DRIFT` means raised by the deterministic drift daemon; `ISSUE` means a human created it; `RP_SIGNOFF` requires regulatory action.	Ticket card + filters
Who actually clicked sign?	Every audit row carries `userId` (real actor) AND `ghostAsUserId` (when an owner was viewing-as someone else). Hash-chained — tampering breaks the chain on next verify.	AuditLog table + /audit/ghost

02 ## The 7-layer defence

Every layer is live and verifiable in browser tonight.

---

1 **Grounded context, not free generation** LIVE

Each agent receives a live DB digest as its only context. System prompt explicitly forbids invention: *"Do not invent facts. If the bundle doesn't support a claim, do not make it."*

2 **Anti-fabrication system prompts** LIVE

Composer ends with explicit *"Outstanding: <list of fields the RP still needs to gather>"* when data is thin — uncertainty is visible, not hidden.

3 **Read-only architecture** LIVE

No AI agent can mutate the database. Composer drafts go to a separate field. Concierge briefs are informational. Chat is read-only. Mutations require explicit human action with role-gated buttons.

4 **Three-person sign-off on every regulated artefact** LIVE

RP (Berne) → DAR (Coenie) → AR (Ilse). Each name recorded with timestamp. AR approval freezes a versioned snapshot for the regulator PDF. If the AI hallucinated, RP catches it; DAR is the second gate; AR is the third.

5 **Hash-chained AuditLog (operational actions)** LIVE

Every operational action — by human, by system, by ghost actor — chained via SHA-256. `verifyHashChain()` exists; tampering breaks the chain on next verification.

6 **Hash-chained AICall log (every AI call)** LIVE

Every Claude API call is logged: prompt, response, model, sources used, token usage, real actor + ghost target. Hash-chained. SAHPRA can pull this and reproduce any AI-generated artefact byte-for-byte.

7 **Visible provenance — UI never hides AI involvement** LIVE

Sources footer in chat. Red watermark on AI drafts. Adaptive-thinking summary toggle on Concierge brief. The user always knows when an AI touched it and what it saw.

03 Live evidence — three things to click

Run these in the browser to demonstrate, not just describe.

1 · Open the chat (bottom-right bubble) and ask anything

```
# Ask: "What's overdue right now?"

Reply: The single open ticket is the SMF C.3.1 drift flag,
       priority HIGH, age 11 hours. Renae owns the floor-plan
       refresh; Berne re-signs after applying the AI redraft.

Grounded in live data
50 plants · 2 active batches · 1 open ticket
{AR_APPROVED:2, DRAFT:56} smf sections by status
1 smf stale · 11 key personnel
2222222 licence · 263 days to expiry
```

2 · Open SMF → any signed section → click "Draft with AI"

```
┌───────────────────────────────────────────────────────────┐
│ AI-GENERATED  ·  NOT YET APPROVED                          │
│ Opus 4.7 proposal · review carefully before applying      │
│ all 3 sign-offs reset on Apply  ·  drafted 14:38 today    │
└───────────────────────────────────────────────────────────┘

The IF facility, operated by ILCO Farms at Hardus Farm,
Viljoenskroon, comprises a single contiguous site dedicated
to medicinal cannabis cultivation and primary processing...

[ Apply (resets sign-off chain) ]   [ Discard ]
```

3 · Query the AICall audit table

```
$ psql -d tntza -c "SELECT agent, model, \"durationMs\",
                       \"outputTokens\", LEFT(\"hashChain\",12)
                       FROM \"AICall\" ORDER BY timestamp DESC LIMIT 5;"

agent       | model                | durationMs | outputTokens | hashChain
------------+---------------------+------------+--------------+--------------
GENERAL_OPS | claude-sonnet-4-6   |       6800 |          412 | 2b798e5fb72e
MAESTRO     | claude-haiku-4-5    |        920 |           38 | a50b96dd0581
CONCIERGE   | claude-opus-4-7     |      15700 |          776 | 7c9e4f1a2b03
COMPOSER    | claude-opus-4-7     |      14200 |          776 | 5d8c2a1f9e4b

→ Inspector says: "Show me the C.3.1 redraft from Tuesday."
   We replay the row: who, what model, what data, what came back.
```

04 Talking points for the meeting

When asked the hard question, give these in order.

"How do you know the AI isn't lying?"

It can't write to the regulated record. Every AI output is a *proposal*. Three humans must sign off — RP (Berne), DAR (Coenie), AR (Ilse) — before anything becomes the SMF.

"How do you know it isn't making numbers up?"

It only sees real data, not training data. We feed each agent a live snapshot from the actual database, and the system prompt explicitly forbids fabrication. The chat shows the exact facts that grounded each answer.

"Can you reproduce a decision later if SAHPRA asks?"

Every AI call is logged with prompt, response, sources, model, token usage, hash chain. We can replay any answer the AI gave on any day, byte-for-byte, and show what data fed it.

"What if the AI says we're compliant and we're not?"

It doesn't make compliance claims. The AI *proposes draft text*, the RP *verifies and signs*, the DAR *verifies and signs*, the AR *approves and freezes the snapshot*. The signature is the truth, not the AI text.

"Who is accountable when the AI is wrong?"

The named human signatories on the regulated artefact. Berne for clinical / SMF content; Ilse + Coenie for owner-level decisions; Renae for facility ops. The AI accelerates the work; the licences they hold carry the accountability.

"What stops a staff member trusting the AI blindly?"

Every AI-generated draft has a bold red "AI-GENERATED · NOT YET APPROVED" banner. Sources visible below every chat answer. Status badges show DRAFT vs RP_SIGNED vs AR_APPROVED. There is no UI surface where AI text is presented as an established fact.

05 What we explicitly do not claim

If anyone tries to put these words in your mouth, push back.

- ✗ **"The AI never hallucinates."** It can. We assume it does. The 7 layers are designed for that reality.
- ✗ **"The AI replaces the RP."** It assists. RP signs. The signature is what counts to SAHPRA.
- ✗ **"The AI is bound by SAHPRA regulations."** Models don't have legal awareness — humans do. The AI has prompts about regulatory tone; legal compliance is the RP's signature.
- ✗ **"The system is autonomous."** Every regulated action requires a named human signatory. There is no auto-publish path.
- ✗ **"Drift catches every event."** 16 specific event types covered. Comprehensive but not omniscient.

06 Footprint & cost

For the budget question, before it's asked.

COMPONENT	PER CALL	INDICATIVE MONTHLY
Owner Concierge (Opus 4.7)	~R8 per brief	~R600 (assumes daily generation)
SMF Composer (Opus 4.7)	~R6 per draft	~R400 (5–10 redrafts/month)
Maestro router (Haiku 4.5)	~R0.005 per message	~R30
General Ops chat (Sonnet 4.6)	~R0.50 per question	~R200–R600 (usage-driven)
AICall + audit logging	~3–15KB DB write each	negligible
	TOTAL AT EXPECTED VOLUME	~R1,300–R1,700/MONTH

07 The honest closer

Read this verbatim if you have the floor for sixty seconds.

> *From day one, we assumed the AI might be wrong. So we built four hard answers into the system itself.*
>
> 1. **It cannot write to the regulated record.** Every AI output is a proposal that lands in front of a named human — Berne for SMF sections, Ilse for owner decisions, Renae for facility calls.
> 2. **The audit log records everything.** What the AI saw, what it said, who looked at it, who approved it. All hash-chained. All replayable.
> 3. **If SAHPRA asks "how was C.3.5 written?"** we show them the original PDF excerpt, the live data digest the AI received, the model output, the RP's review note, the DAR's verification, and the AR's signature — all timestamped and tamper-evident.
> 4. **The accountability stays with the people who hold the licences.** The AI accelerates the work. The signature is what counts.
>
> *AI accelerates. Humans remain accountable.*